

Helpdesk - scenariusze zagrożeń i wymagania bezpieczeństwa

Scenariusze zagrożeń

Scenariusz 1 - misuse case: podgląd cudzego zgłoszenia

Aktor: pracownik helpdesku.

Motyw: chce szybciej sprawdzić dane klienta albo robi to z ciekawości, mimo że nie powinien.

Cel: uzyskanie dostępu do zgłoszenia innego klienta bez odpowiednich uprawnień.

Kroki: loguje się do systemu -> otwiera zgłoszenie, do którego ma dostęp -> zmienia identyfikator zgłoszenia w adresie URL -> system nie sprawdza poprawnie uprawnień -> wyświetla się cudze zgłoszenie.

Naruszony element CIA: poufność, ponieważ dane klienta trafiają do osoby, która nie powinna ich widzieć.

Scenariusz 2 - atak: brute force na konto klienta

Aktor: zewnętrzny atakujący.

Motyw: chce przejąć konto klienta i uzyskać dostęp do jego danych oraz historii zgłoszeń.

Cel: zalogowanie się na cudze konto.

Kroki: zdobywa login, np. adres e-mail klienta -> próbuje wiele haseł -> system nie ogranicza liczby prób logowania -> konto nie jest czasowo blokowane -> atakujący trafia poprawne hasło -> loguje się do systemu.

Naruszony element CIA: poufność i integralność, ponieważ atakujący może czytać dane i zmieniać treść zgłoszeń lub ustawienia konta.

Scenariusz 3 - atak: przeciążenie systemu zgłoszeniami

Aktor: zewnętrzny atakujący lub bot.

Motyw: chce utrudnić działanie firmy albo zablokować dostęp prawdziwym użytkownikom.

Cel: obniżenie wydajności lub całkowite zablokowanie systemu Helpdesk.

Kroki: automatycznie wysyła dużą liczbę zgłoszeń i żądań do API -> backend próbuje wszystko obsłużyć -> baza danych jest przeciążona -> system działa coraz wolniej albo przestaje odpowiadać -> klienci i pracownicy nie mogą korzystać z systemu.

Wymagania Bezpieczeństwa

Wymaganie	Uzasadnienie (dlaczego ma sens)	Adresowany scenariusz / zagrożenie
System musi ograniczać liczbę prób logowania.	To ogranicza brute force, ponieważ po kilku nieudanych próbach blokuje dalsze zgadywanie hasła i utrudnia przejście konta.	Scenariusz 2
System musi walidować dane wejściowe po stronie backendu i frontendu.	To chroni przed wstrzyknięciem złośliwego kodu, np. XSS, który mógłby zostać wykonany w przeglądarce użytkownika.	Scenariusz 1 oraz inne zagrożenia związane z danymi wejściowymi
System musi sprawdzać uprawnienia użytkownika przy każdym odczycie zgłoszenia.	To zapobiega dostępowi do cudzych danych, ponieważ backend weryfikuje, czy użytkownik ma prawo zobaczyć konkretne zgłoszenie.	Scenariusz 1
Hasła użytkowników muszą być przechowywane w postaci hashy.	To chroni dane po wycieku bazy, ponieważ hasła nie są zapisane w formie jawnej i trudniej je odzyskać.	Scenariusz 2
System musi używać HTTPS dla całej komunikacji.	To chroni dane logowania i inne dane w trakcie przesyłania, ponieważ bez szyfrowania mogą zostać przechwycone.	Scenariusz 2 oraz ogólne zagrożenia transmisji danych
System musi stosować rate limiting dla formularza zgłoszeń i API.	To chroni przed przeciążeniem, ponieważ ogranicza liczbę żądań wysyłanych przez jednego użytkownika lub adres IP.	Scenariusz 3
System musi logować zdarzenia bezpieczeństwa, np. nieudane logowania i nietypową liczbę żądań.	To pozwala wykrywać podejrzanе działania i analizować ataki po ich wystąpieniu.	Scenariusz 2, Scenariusz 3
E-maile z powiadomieniami nie mogą zawierać pełnych danych wrażliwych.	To chroni dane poza systemem, ponieważ wiadomość e-mail może trafić do niepowołanej osoby albo zostać podejrzana na innym urządzeniu.	Scenariusz 1 oraz inne zagrożenia związane z ujawnieniem danych

Mapowanie na OWASP Top 10

Wymaganie	Kategoria OWASP	Uzasadnienie
Ograniczenie liczby prób logowania	Identification and Authentication Failures	Dotyczy błędów w uwierzytelnianiu i braku ochrony przed zgadywaniem haseł.
Walidacja danych wejściowych	Injection	Brak walidacji może prowadzić do wstrzyknięcia złośliwego kodu lub niepoprawnych danych.
Kontrola dostępu do zgłoszeń	Broken Access Control	Użytkownik może uzyskać dostęp do cudzych danych mimo braku uprawnień.
Hashowanie haseł	Cryptographic Failures	Nieprawidłowe przechowywanie danych wrażliwych zwiększa skutki wycieku bazy danych.
HTTPS	Cryptographic Failures	Brak szyfrowania danych w transmisji może prowadzić do ich przechwycenia.
Rate limiting	Security Misconfiguration	Brak limitów może prowadzić do przeciążenia systemu i ułatwiać nadużycia.
Logowanie zdarzeń bezpieczeństwa	Security Logging and Monitoring Failures	Brak logów utrudnia wykrywanie incydentów i późniejszą analizę ataku.
Ograniczenie danych w e-mailach	Pośrednio: Cryptographic Failures / brak idealnego dopasowania	To wymaganie dotyczy ograniczenia ujawniania danych poza systemem. Nie pasuje idealnie do jednej kategorii, ale najbliższej mu do ochrony danych wrażliwych.